

Meridian & Associates LLP

Global Professional Services

Data Privacy Policy

Version 4.3

Effective Date: January 2026

Classification: Confidential

Prepared by the Office of Strategic Communications

Meridian & Associates LLP

CONFIDENTIAL

This document contains proprietary information. Do not distribute outside of authorized RFP response teams without written consent.

Table of Contents

1	Policy Purpose and Scope
2	GDPR Compliance Framework
3	U.S. Privacy Compliance (CCPA/CPRA)
4	HIPAA Compliance
5	China PIPL Compliance
6	Cross-Border Data Transfers
7	Data Subject Rights
8	Privacy Impact Assessments
9	Data Retention and Disposal
10	Data Protection Officer
11	Breach Notification Procedures
12	AI and Data Processing
13	Privacy by Design

1. Policy Purpose and Scope

This Data Privacy Policy establishes the principles, standards, and procedures by which Meridian & Associates LLP collects, processes, stores, and disposes of personal data in all jurisdictions where we operate. The policy applies to all personal data processed by the firm, whether relating to clients, employees, contractors, job applicants, website visitors, or any other data subjects.

Meridian recognizes that privacy is a fundamental right and a cornerstone of trust. Our approach is to apply the highest applicable standard globally -- where local law imposes stricter requirements, those requirements take precedence; where local law is less prescriptive, the GDPR standard applies as our baseline.

2. GDPR Compliance Framework

As a firm with significant operations in the European Economic Area and processing substantial volumes of EU personal data, GDPR compliance is a foundational element of our privacy program.

2.1 Lawful Bases for Processing

- Client engagement data: Legitimate interest (delivery of contracted services) and contractual necessity.
- Employee data: Contractual necessity, legal obligation, and legitimate interest.
- Marketing data: Consent (explicit opt-in for electronic marketing).
- Special category data: Explicit consent or substantial public interest (where applicable).

2.2 Records of Processing Activities (ROPA)

Meridian maintains a comprehensive ROPA covering all processing activities across all entities, updated quarterly. The ROPA includes: purpose of processing, categories of data subjects, data categories, recipients, transfer mechanisms, retention periods, and security measures. The ROPA is managed centrally via OneTrust and is available to supervisory authorities upon request.

2.3 Data Protection Impact Assessments

DPIAs are mandatory for any processing that is likely to result in a high risk to data subjects, including: large-scale profiling, systematic monitoring, processing of special categories at scale, and new technology deployments involving personal data. In FY2025, 89 DPIAs were completed.

3. U.S. Privacy Compliance (CCPA/CPRA)

Meridian complies with the California Consumer Privacy Act (as amended by the California Privacy Rights Act) and monitors emerging state privacy laws across all 50 states. Current compliance covers:

- California (CCPA/CPRA) -- Full compliance including data minimization, purpose limitation, and automated decision-making opt-out.
- Virginia (VCDPA), Colorado (CPA), Connecticut (CTDPA), Utah (UCPA), Texas (TDPSA), Oregon (OCPA) -- Compliant with all enacted state privacy laws as of January 2026.
- Do Not Sell/Share -- Meridian does not sell personal information. We honor Global Privacy Control (GPC) signals

as opt-out requests.

- Service Provider Agreements -- All U.S. vendor contracts include CCPA-compliant service provider terms with restrictions on use, retention, and disclosure.

4. HIPAA Compliance

Healthcare & Life Sciences represents 18% of Meridian's global revenue, making HIPAA compliance a critical component of our privacy program. Meridian acts as a Business Associate under HIPAA for engagements involving protected health information (PHI).

- Business Associate Agreements (BAAs): Executed with all healthcare clients before any PHI is accessed or processed. BAA template aligned with 45 CFR 164.504(e).
- HIPAA Security Rule: Administrative, physical, and technical safeguards implemented across all systems handling PHI, including AES-256 encryption, role-based access controls, automatic session timeout, and audit logging with 7-year retention.
- HIPAA Privacy Rule: Minimum necessary standard enforced for all PHI access. Workforce members access only the PHI required for their specific engagement role.
- HITRUST CSF v11 certification: Maintained across all healthcare delivery environments, providing a comprehensive control framework that incorporates HIPAA, NIST, and ISO 27001 requirements.
- Dedicated healthcare privacy team: 8 privacy professionals specializing in healthcare data regulations, including HIPAA, HITECH, 42 CFR Part 2 (substance use disorder records), and state-specific health privacy laws.
- PHI breach history: Zero reportable PHI breaches in the past 5 fiscal years.
- Training: HIPAA-specific training mandatory for all professionals assigned to healthcare engagements. Annual refresher with 100% completion rate in FY2025.

5. China PIPL Compliance

Meridian operates five offices in Greater China (Shanghai, Beijing, Hong Kong, Shenzhen, and Guangzhou) with approximately 2,200 professionals. Compliance with China's Personal Information Protection Law (PIPL), effective November 2021, is managed through a dedicated China Privacy Program.

- Local data residency: All personal information of Chinese data subjects is stored on servers located within mainland China (hosted on Alibaba Cloud, Beijing region) in compliance with PIPL Article 40 and the Cyberspace Administration of China (CAC) data localization requirements.
- Cross-border transfers: Where personal information must be transferred outside China (e.g., for global HR processes or cross-border engagements), Meridian has completed the CAC-mandated Standard Contract filing and Security Assessment as required by the Measures on Standard Contracts for Cross-Border Transfers of Personal Information.
- Consent management: Separate, informed consent obtained for all personal information processing in China, in compliance with PIPL Articles 13-14. Enhanced consent procedures for sensitive personal information (biometric, financial, location data).
- Personal Information Protection Impact Assessments (PIPIAs): Conducted for all processing activities involving Chinese personal information that meet PIPL Article 55 thresholds. 12 PIPIAs completed in FY2025.
- DPO equivalent: A dedicated Personal Information Protection Officer has been appointed for Meridian's China operations, as required by PIPL Article 52.

- Regulatory engagement: Active participation in CAC and Ministry of Industry and Information Technology (MIIT) consultation processes on implementing regulations.

6. Cross-Border Data Transfers

Given our global operations, cross-border data transfers are inherent to our business. Meridian employs the following mechanisms to ensure lawful transfers:

- Standard Contractual Clauses (SCCs) -- EU-approved SCCs (June 2021 version) are incorporated into all inter-company and vendor agreements involving transfers from the EEA.
- Binding Corporate Rules (BCRs) -- Meridian's BCRs were approved by the Irish Data Protection Commission (as lead authority) in 2024 and are recognized across all EEA member states.
- Transfer Impact Assessments (TIAs) -- Conducted for all transfers to countries without an adequacy decision. TIAs evaluate the legal framework of the recipient country, supplementary measures applied, and residual risk.
- UK International Data Transfer Agreement (IDTA) -- Used for transfers from the UK post-Brexit.
- APEC Cross-Border Privacy Rules (CBPR) -- Certified for transfers within the APEC framework.
- Supplementary Measures -- Including encryption in transit and at rest, pseudonymization, and contractual prohibitions on government access disclosure.

7. Data Subject Rights

Meridian has established a centralized Data Subject Rights portal (privacy.meridianllp.com) that enables individuals to exercise the following rights:

- Right of Access -- Response within 30 days (GDPR) / 45 days (CCPA).
- Right to Rectification -- Inaccurate data corrected within 10 business days.
- Right to Erasure (Right to be Forgotten) -- Processed within 30 days, subject to legal holds and regulatory retention requirements.
- Right to Restriction of Processing -- Implemented within 5 business days.
- Right to Data Portability -- Machine-readable export provided within 30 days.
- Right to Object -- Objections to processing assessed within 15 business days.
- Rights Related to Automated Decision-Making -- Human review available upon request for any decision made solely by automated means.

In FY2025, Meridian processed 2,340 data subject requests with an average response time of 18 days and a 100% on-time completion rate.

8. Privacy Impact Assessments

Privacy Impact Assessments (PIAs) are integrated into the firm's project lifecycle methodology. A PIA is required before the launch of any new system, application, or process that involves personal data. The PIA process includes: data mapping, risk identification, controls assessment, and sign-off by the DPO. High-risk PIAs require review by the Privacy Steering Committee.

9. Data Retention and Disposal

Meridian's data retention schedule is based on the principle of data minimization:

- Active client engagement data: Duration of engagement + 7 years (regulatory minimum).
- Client proposals and RFP responses: 3 years from submission.
- Employee records: Duration of employment + 7 years (or longer if required by local law).
- Job applicant data: 2 years from decision date (or 6 months in jurisdictions requiring shorter retention).
- Marketing consent records: Duration of consent + 3 years.
- System logs and audit trails: 13 months (standard) / 7 years (for regulated engagements).

Data disposal follows NIST SP 800-88 guidelines. Electronic media is sanitized via cryptographic erasure or physical destruction. Paper records are cross-cut shredded. Disposal certificates are retained for audit purposes.

10. Data Protection Officer

Meridian has appointed a Global Data Protection Officer (DPO) as required by Article 37 of the GDPR. The DPO operates independently and reports directly to the Board of Partners on all privacy matters.

- Global DPO: Dr. Helena Voss, CIPP/E, CIPM, FIP
- Contact: dpo@meridianllp.com
- EU Representative (Art. 27): Meridian EU Privacy Office, Dublin, Ireland
- UK Representative: Meridian UK Privacy Office, London, United Kingdom

Regional Privacy Officers are appointed in each major jurisdiction and serve as the first point of contact for local regulatory authorities. The DPO is supported by a team of 24 privacy professionals.

11. Breach Notification Procedures

- All suspected or confirmed data breaches must be reported to the Privacy Incident Response Team (PIRT) within 1 hour of discovery via the internal hotline or email.
- The PIRT conducts a preliminary assessment within 4 hours to determine scope, severity, and notification obligations.
- GDPR notification: Supervisory authority notified within 72 hours where required. Data subjects notified without undue delay for high-risk breaches.
- CCPA notification: Affected California residents notified in the most expedient time possible.
- Contractual notification: Affected clients notified within 24 hours per standard DPA terms.
- Post-incident review completed within 30 days with remediation plan and lessons learned.

12. AI and Data Processing

As Meridian expands its use of artificial intelligence and machine learning across client engagements and internal operations, the firm enforces strict controls to ensure personal data is excluded from AI/ML model training and that all AI-driven processing of personal data complies with applicable privacy regulations.

- No personal data in model training: Client personal data and employee personal data are never used to train, fine-tune, or improve AI/ML models -- whether proprietary (MeridianAI) or third-party. This prohibition is enforced through technical controls (data classification tagging, automated PII detection, and training pipeline guardrails) and contractual obligations with all AI/ML vendors.
- AI processing lawful basis: Any processing of personal data by AI systems (e.g., document analysis, anomaly detection in audit, HR analytics) must have a documented lawful basis under GDPR Article 6 (and equivalent provisions under CCPA, PIPL, etc.), recorded in the ROPA.
- Automated decision-making: Where AI systems produce outputs that could materially affect data subjects (e.g., candidate screening, risk scoring), Meridian ensures meaningful human review before any decision is finalized, in compliance with GDPR Article 22.
- Data minimization in AI: Only the minimum necessary personal data fields are provided to AI systems. Pseudonymization and anonymization are applied wherever technically feasible.
- Third-party AI vendor assessments: All AI/ML vendors undergo privacy-specific due diligence including review of data processing terms, sub-processor disclosures, data residency, and model training practices. Vendors that train models on client-provided data are not approved.
- Opt-in policy: Clients must provide explicit written consent before any personal data from their engagement is processed by AI/ML systems beyond standard document search and retrieval.

13. Privacy by Design

Meridian embeds privacy by design and by default into all systems, processes, and services. This includes: data minimization at collection, purpose limitation enforced via technical controls, privacy-preserving default settings, and automated data lifecycle management. All new technology deployments undergo a Privacy Architecture Review before production deployment.